Chapitre 3

Les mécanismes de sécurité
La cryptographie

2024-2025

La cryptographie

Sommaire

- **Introduction**
- **La cryptologie**
- Cryptographie symétrique
- Cryptographie asymétrique
- Le hachage
- Les signatures numériques
- Les certificats numériques

Introduction
Définitions

- **Cryptologie**, ancien art du secret ou nouvelle science des messages secret comprend la cryptographie et la cryptanalyse
  - **Cryptographie** vient des mots grec ancien: Kryptos «caché» et graphie « écriture »: c'est des principes, méthodes et techniques dont l'application assure le chiffrement et le déchiffrement des données, afin d'en préserver la confidentialité, l'authenticité et l'intégrité
  - **Cryptanalyse:** méthodes et procédés de décryptage visant à rétablir en clair un cryptogramme, sans connaissance préalable de la clé de chiffrement.

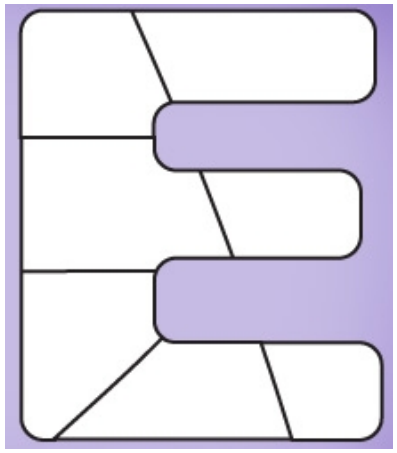
Introduction
Définitions

☞ **Crypter:**rendre illisible un texte en clair sans connaître la clé après.

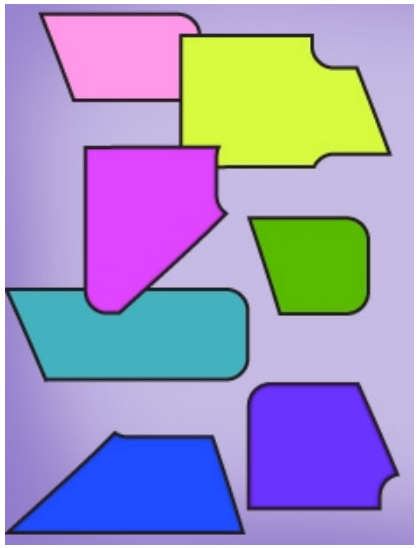
☞ La **clé** est le paramètre utilisé en entrée avec les données lors de l'opération de chiffrement/ cryptage

Exemple: puzzle

☞ **décrypter:** retrouver le texte en clair d'origine sans posséder la clé.



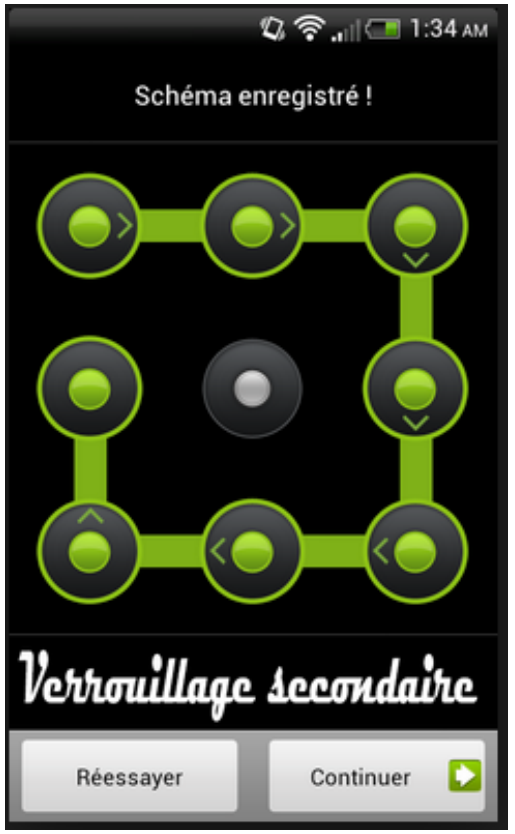
Crypter



Introduction
Définitions

- **Chiffrer:** opération qui transforme un texte en clair en un texte chiffré ou cryptogramme, inexploitable pour quiconque ne possède pas la clé.

- **Déchiffrer**: opération inverse du chiffrement, permettant à partir de la clé, de rétablir, en clair un cryptogramme.



Introduction

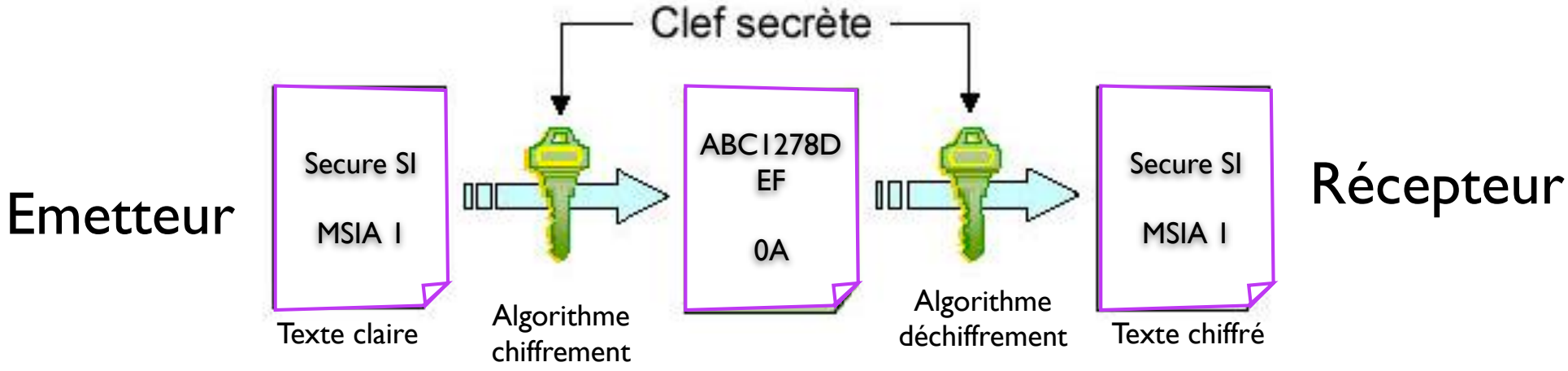
Quelques services de sécurité

- ☑ La confidentialité
- ☑ L'authentification
- ☑ L'intégrité
- ☑ La disponibilité
- ☑ La non répudiation
- ☑ La fraîcheur
- ☑ .....

Cryptographie Symétrique

Cryptographie symétrique ou cryptographie à clé secrète

☛ En cryptographie à clé privée ou à clé secrète ou chiffrement symétrique, les données sont chiffrées et déchiffrées avec la même clé connue seulement de l'émetteur et du récepteur



Un algorithme cryptographique comprend deux fonctions:

☛La fonction **E** (Encryption) noté C=E(K,M): où C (le cryptogramme) est le résultat du message M chiffré avec la clé K.

☛ La fonction **D** (Decryption) noté M=**D**(K,C): où M est le résultat du déchiffrement du cryptogramme C.

Cryptographie symétrique

Chiffrement traditionnel

Les méthodes de chiffrement traditionnelles utilisaient généralement des opérations de décalage, de permutation, de transposition ....

Chiffrement traditionnel

Opération de décalage

- chiffrement alphabétique par décalage (Jules Cesar): utilisé dans l'antiquité romaine
- Avec la clé K=3 (chiffre de César), le texte ABC est chiffré par DEF

A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C

- Le chiffrement de César est **une substitution monoalphabétique** car chaque lettre du texte claire sera toujours chiffré par la même lettre du texte chiffré.

Chiffrement traditionnel

Algorithme du chiffrement alphabétique par décalage: substitution monoalphabétique

Numérotation de 0 à 25 les lettres de l'alphabet.
Choix d'une clé K comprise entre 1 et 25
On chiffre le caractère X par: E(K,X) = (X+K) mod 26
Exemple: chiffrement du message M=ZIG avec K = 3

- Z = 25, 25 + 3 = 28, 28 mod 26 = 2 : C
- I = 8; 8 + 3 = 11, 11 mod 26 = 11 : L
- G = 6, 6 + 3 = 9, 9 mod 26 = 9 : J
- ZIG chiffré donne CLJ

- Problème: lorsque l'algorithme est connu, il est facile d'essayer toutes les 25 clés possibles.
- Si on connait la langue qui est utilisée, on peut user de la fréquence d'apparition des lettres pour estimer le décalage (méthode d'AL-Kindi au neuvième siècle après J.C)

Chiffrement traditionnel

Si la langue utilisée est le Français par exemple, la fréquence d'apparition des lettres est:

A	B	C	D	E	F	G	H	I	J	K	L	M
7,68	0,8	3,32	3,6	17,76	1,06	1,1	0,64	7,23	0,19	0	5,89	2,72

N	O	P	Q	R	S	T	U	V	W	X	Y	Z
7,61	5,34	3,24	1,34	6,81	8,23	7,3	6,05	1,27	0	0,54	0,21	0,07

AL-Kindi:

- Le texte: « Le problème est que lorsque l'algorithme est connu » est chiffré par « Oh sqreohph hvw txh orutxh odojrulwkph hvw frqqx » avec un un clé de 3 .
- La lettre E la plus fréquente est E, donc codée par h dans le texte chiffré.
- Donc il faut faire en sorte qu'une lettre ne soit toujours pas chiffrée de la même façon .
- NB: La robuste dépendra de la taille de l'alphabet et n'évolue pas car la clé ne varie pas

Chiffrement traditionnel

Opération de permutation

- Algorithme : remplacer chaque lettre par une autre lettre (substitution monoalphabétique)

A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
X	Y	Z	A	B	C	U	V	W	D	E	F	R	S	T	G	H	I	O	P	Q	J	K	L	M	N

WELCOMETOUASZ

KBFZTRBPTQXON

☛ Même si l'algorithme est connu, il est impossible d'essayer les 26!-1 clés possibles c.-à-d.

403291461126605635583999999

NB: La robuste dépendra de la taille de l'alphabet et n'évolue pas car la clé ne varie pas

Chiffrement traditionnel

- Chiffrement par substitution poly-alphabétique (chiffrement de Vigenère)
  - Utilise un mot comme clé au lieu d'un simple caractère (comme dans Cesar).
  - A chaque lettre du texte clair on fait correspondre une lettre de la clef (la clef étant répétée autant de fois que nécessaire): substitution polyalphabétique

A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
1	2	3	4	5	6	7	8	9	10	11	12	13	14	15	16	17	18	19	20	21	22	23	24	25	26

Texte clair →

Z	I	G	U	I	N	C	H	O	R
26	9	7	21	9	14	3	8	15	18

C	A	S	A
3	1	19	1

→ Clé

Z+C	I+A	G+S	U+A	I+C	N+A	C+S	H+A	O+C	R+A
26+3=29=3	9+1=10	7+19=26	21+1=22	9+3=12	14+1=15	3+19=22	8+1=9	15+3=18	18+1=19

Texte chiffré ↓

C	J	Z	V	L	O	V	I	R	S

☞ Si l'algorithme est connu, il y a 26^4 Clés possibles

☞ NB: La robuste dépend de la taille de l'alphabet et de celle la de la clé qui varie

Chiffrement traditionnel

Opération de transposition

- Algorithme : permuter les lettres selon une permutation fixe
  - Clé: 123456 -> 642531
    - WELCOMETOUASZ
    - MCEOLWSUTAOEZ

☛ NB: La robuste dépend de la taille de l'alphabet et de celle la de la clé qui varie

☛ Pour une clé de longueur N, on a N!-1 clés

☛ Si N=26, on a la même robustesse que l'algorithme de permutation

Chiffrement traditionnel

- Quand on étudie un système, on part du principe que l'attaquant connait le système de chiffrement utilisé sauf la clé: principe de **Kerckhoffs**.
- La sécurité du système doit toujours se reposer sur la clé, et le système restera sûr même si l'algorithme est connu.

Cryptographie symétrique

Chiffrement moderne

- **Chiffrer**
  - **Exemple avec OU Exclusif**

100111=texte claire

110011=Clé

⊕ 100111=texte claire

110011= Clé

= 010100=texte chiffré

- **Déchiffrer**

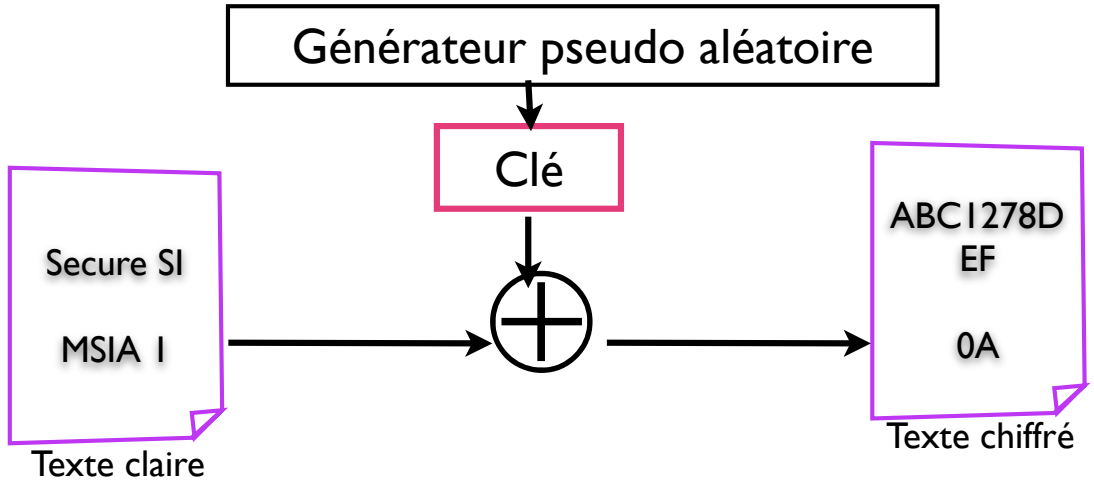
⊕ 010100=texte chiffré

110011= Clé

= 100111=texte claire

Cryptographie symétrique
Chiffrement moderne

☛Chiffrement de **Vernam** (1917) avec un simple opérateur XOR par exemple comme mode opérateur et la clé (pseudo-aléatoire)

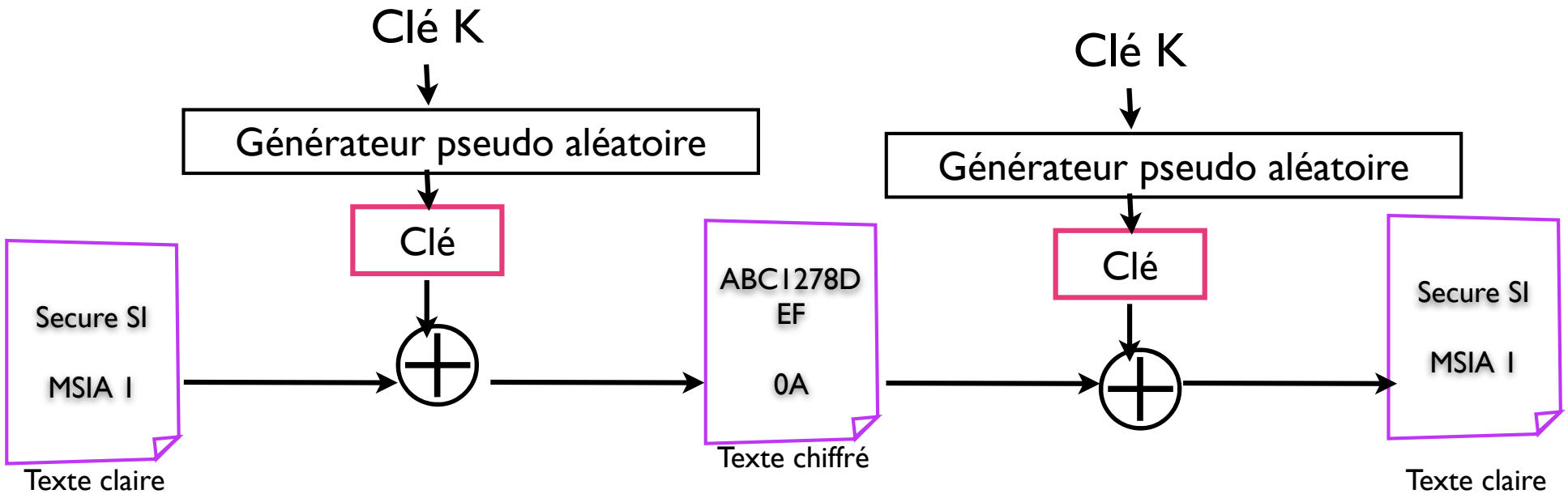


Si le mécanisme de génération de clé est prévisible, même si l le canal de transmission de la clé est sur, la clé peut être connue

- La clé est aussi longue que les données
- La clé est utilisée une seule fois (pas commode pour la transmission secrète de la clé aussi longue que le message): partager le message à la place de la clé.
- Les clés doivent être plus courtes que les messages à chiffrer et réutilisées plusieurs fois
  - Deux modes de chiffrement
    - Chiffrement par flux
    - Chiffrement par bloc

Chiffrement moderne: par flux

☛ C'est un chiffrement à la volée(bit par bit), pas besoin d'avoir la longueur du message pour commencer à chiffrer, il peut se faire avec un simple opérateur XOR



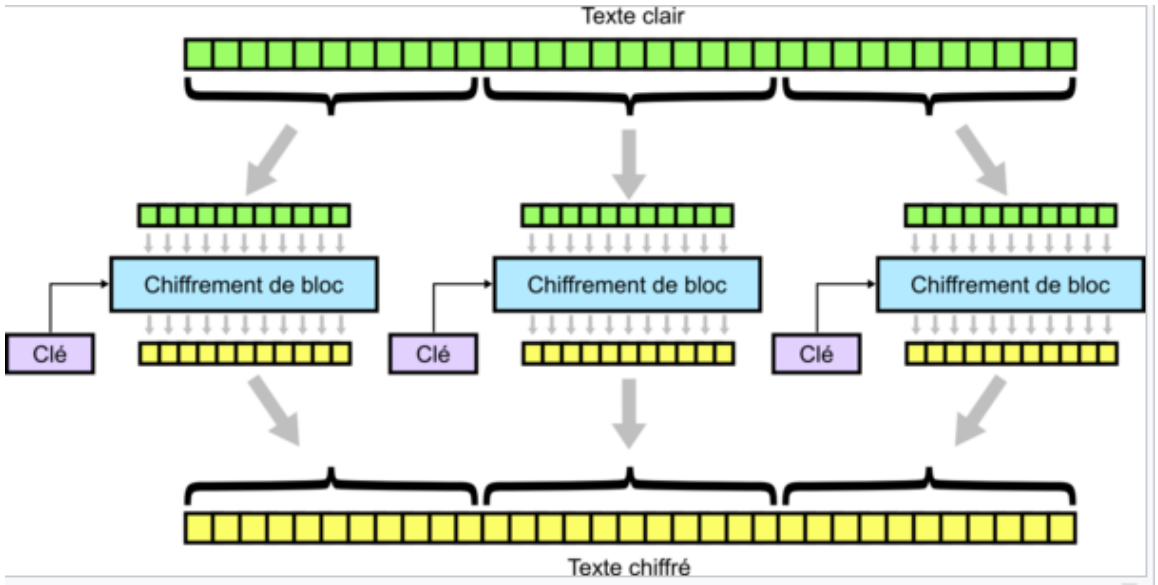
- Mode adapté pour la communication à temps réel, pas besoin d'attendre l'arrivé du bloc entier
- Implémenté en générale sur des supports matériels

Chiffrement moderne: par flux

- Algorithmes très utilisés pour protéger les données multimédia.
  - RC4 (Rivest Cipher 4): plus utilisé, surtout en SSL et dans le Wifi 802.11
  - A5/1, A5/2, A5/3 utilisés en télécommunication dans le GSM
  - E0 pour les liaison bluetooth

Chiffrement moderne: par bloc

☛ Texte divisé en blocs de taille fixe, et chaque bloc est chiffré donnant un bloc chiffré obtenu par substitution, permutation et combinaison avec XOR.

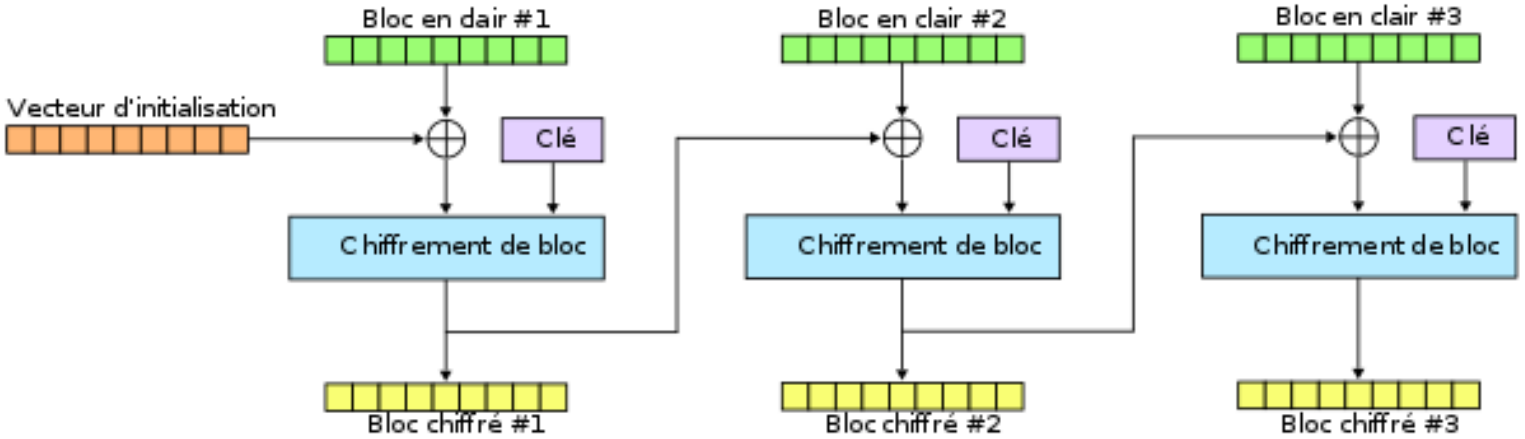


Mode EBC: Electronic Code Book

- chaque bloc doit être entièrement disponible avant le traitement
- La même clé et la même fonction sont utilisées pour chiffrer les blocs suivants

Chiffrement moderne: par bloc

☛**Enchaînement des blocs : « Cipher Block Chaining » (CBC):** on applique sur chaque bloc un XOR avec le chiffrement du bloc précédent avant qu'il soit lui-même chiffré. Afin de rendre chaque message unique, un Vecteur d'Initialisation (IV) est utilisé.



Autres modes: Chiffrement à rétroaction : « Cipher Feedback » (CFB), Chiffrement à rétroaction de sortie : « Output Feedback » (OFB), Chiffrement basé sur un compteur : « CounTeR » (CTR), Chiffrement avec vol de texte : « CipherText Stealing » (CTS), Chiffrement par propagation des chiffrés en chaine « Propagating Cipher Block Chaining » (PCBC), OU exclusif-Chiffrement-OU exclusif : « Xor-Encrypt-Xor » (XEX) etc…

Chiffrement moderne: par bloc

- Algorithmes de chiffrement par bloc
  - DES (Data Encryption Standard)
  - Triple DES
  - IDEA (Internation Data Encryption Algorithm)
  - RC5
  - AES (Advanced Encryption Standard)
  - Blowfish

Résistance aux attaques

- La capacité de résistance d'un mécanisme cryptographique dépend:
  - ☞ L'algorithme choisi (effet d'avalanche, vulnérabilité comme certaines attaques comme celle par fréquence est…)
  - ☞ La confidentialité de la clé
  - ☞ Le nombre clés
  - ☞ La taille des clés.
  - ☞ etc.....

Cryptographie symétrique
Principale problèmatique

Comment se partager la clé ? Difficile à échanger?

- Rencontres personnelles
- Parties de clé envoyées par des canaux séparés

- Sans l'aide d'un tier, beaucoup de clés à gérer
- 2 personnes: 1 clés
- N personnes:n*(n-1)/2 clés
- 100 personnes: 4950 clès

Alternative: Cryptographie à clé publique! ou échange de Diffie Hellman?

Cryptographie Asymétrique

Cryptographie asymétrique ou cryptographie à clé publique

☛ En cryptographie asymétrique, deux clés différentes et liées mathématiquement sont utilisées.

- **Une clé publique**: **connue de tous**
  - Utilisée pour envoyer des messages chiffrés au propriétaire qu'il pourra déchiffrer avec la clé privée correspondante
- **Une clé privée**: **confidentielle**
  - Permet de déchiffrer tout message chiffré avec la clé publique correspondante

☛ Il est facile de dériver la clé publique de la clé privé, l'inverse revient à résoudre un problème de calcul qui doit être difficilement résolvable selon le niveau de sécurite

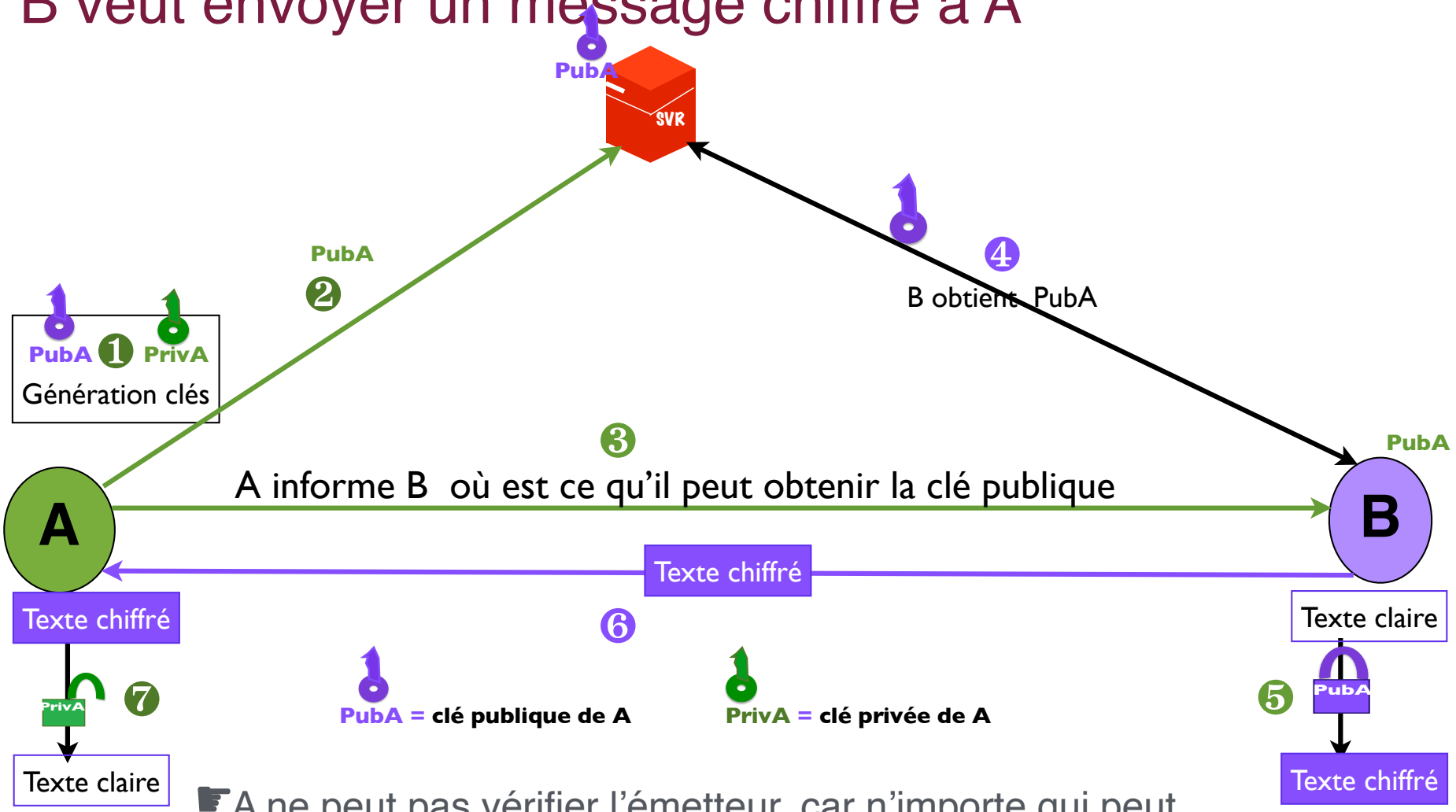
Cryptographie asymétrique chiffrer avec la clé publique

☞ En cryptographie asymétrique, le processus est initialiser par le récepteur pour l'envoie de message chiffré (confifentiel).
Exemple: B veut envoyer un message à A / A veut recevoir un message de B

- Accord d'utiliser la cryptographie asymétrique pour chiffrer le message
- 1-A génère la paire de clés(clé publique de A et clé privée de A)
- 2-A garde la clé privée et donne à B la clé publique
- 3-B chiffre son message avec la clé publique de A
- 4-A reçoit le message et le déchiffre avec sa clé privée.

Cryptographie asymétrique
chiffrer avec la clé publique

☛B veut envoyer un message chiffré à A



☛A ne peut pas vérifier l'émetteur, car n'importe qui peut disposer de sa clé publique et lui envoyer un message?

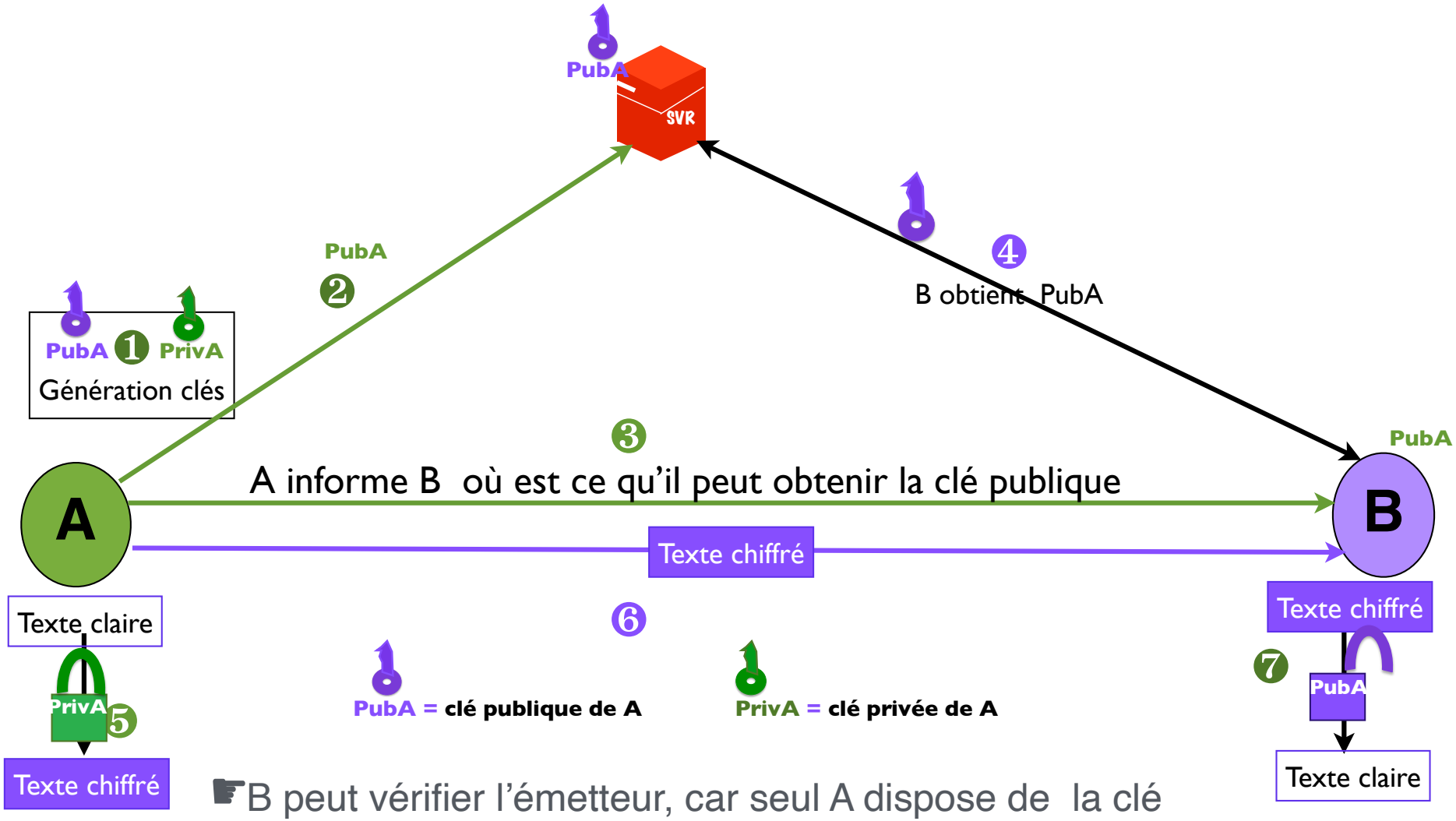
Cryptographie asymétrique
chiffrer avec la clé privée

☛ En cryptographie asymétrique, le processus est initialiser par l'émetteur pour l'envoie de message chiffré (non confidentiel): authentification.
Exemple: A veut envoyer un message à B

- Accord d'utiliser la cryptographie asymétrique pour chiffrer le message
- 1-A génère la paire de clés(clé publique de A et clé privée de A)
- 2-A garde la clé privée et donne à B la clé publique
- 3-A chiffre son message avec sa clé privée
- 4-B reçoit le message et le déchiffre avec la publique de A.

Cryptographie asymétrique
chiffrer avec la clé privée

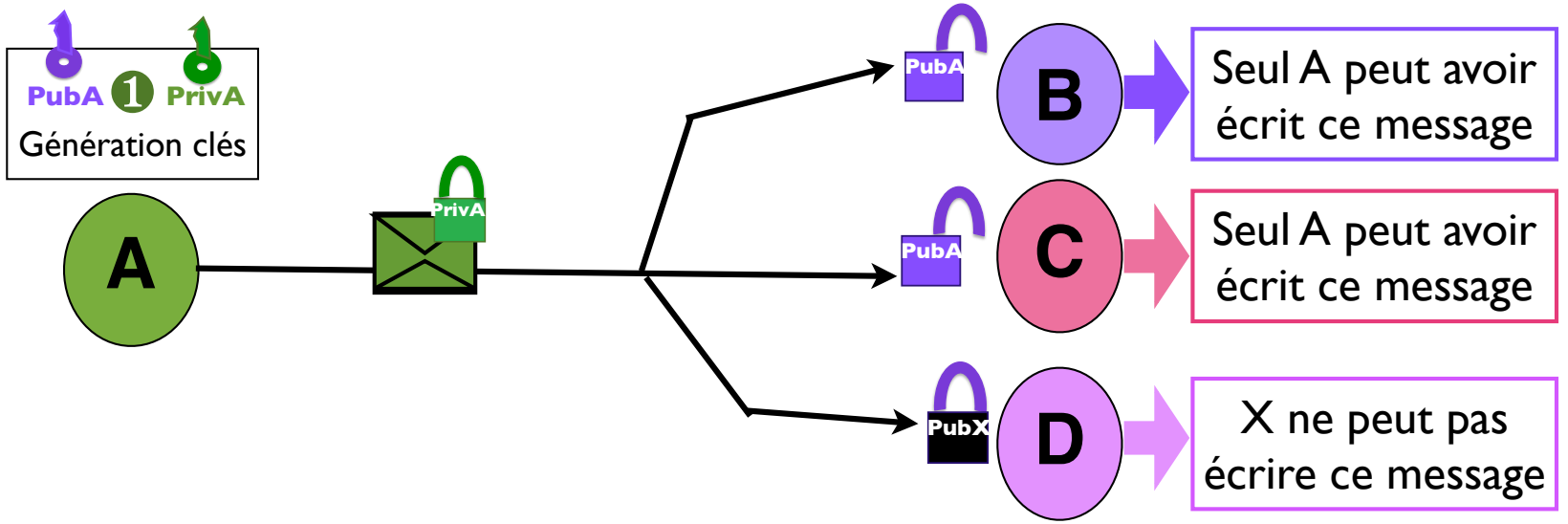
☛ A veut envoyer un message chiffré à B



☛B peut vérifier l'émetteur, car seul A dispose de la clé privée permettant de chiffrer ce message

Cryptographie asymétrique
chiffrer/déchiffrer avec une clé

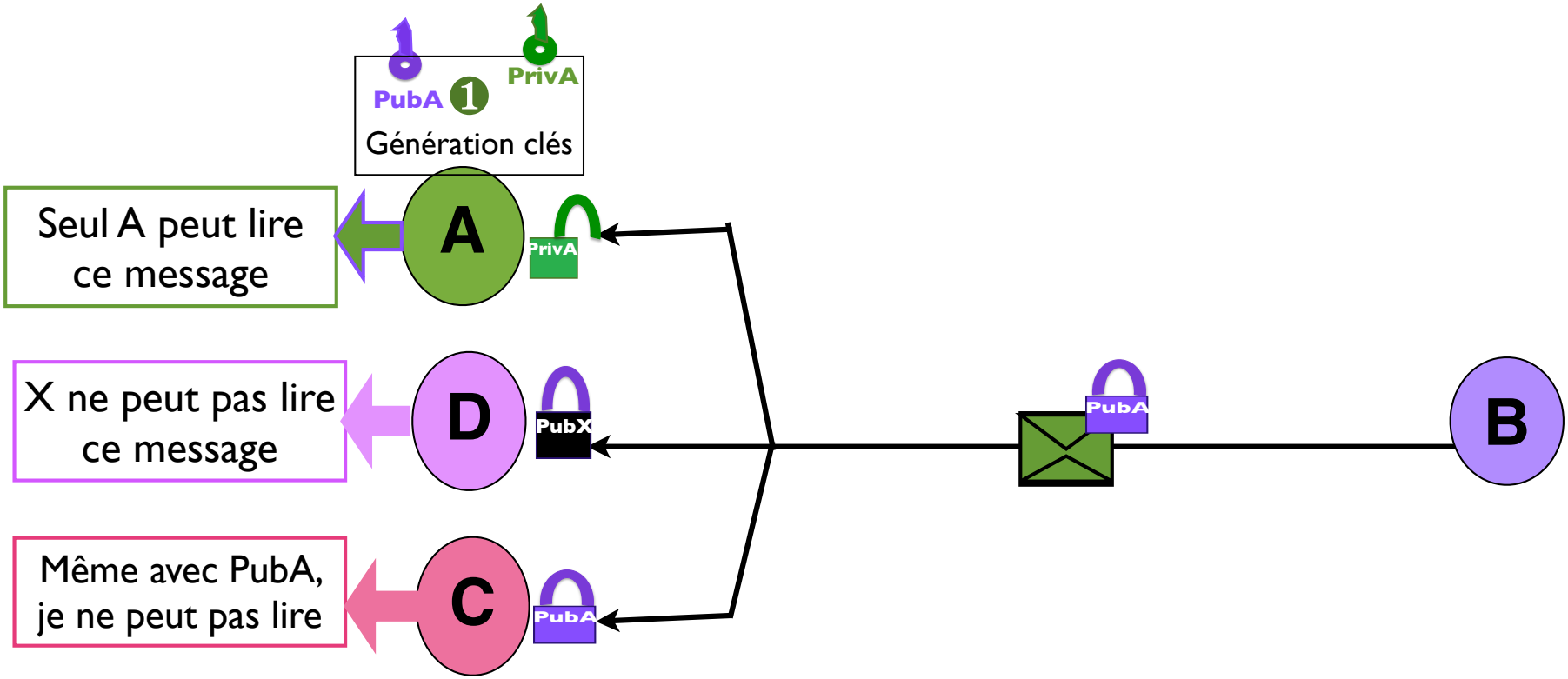
☛ A veut envoyer un message chiffré à B



Authentification de A par B et C.
Le message est il secret même s'il a été envoyé chiffré??

Cryptographie asymétrique
chiffrer/déchiffrer avec une clé

☞ B veut envoyer un message chiffré à A



Confidentialité du message

Qui l'a envoyé ???

Sécurité des algorithmes asymétriques
Le problème de la factorisation des entiers

- Etant donné deux nombres premiers *p* et *q*.
  - Facile de fair la multiplication ***N= p.q***
- Etant donné N
  - Difficile de trouver *p* et *q* (surtout si N grand)

- C'est la difficulté présumée de la factorisation des grands nombres
- **RSA (1977)** repose sur ce système
  - Génération de clé
  - Chiffrement/Déchiffrement/Signature/Vérification

Sécurité des algorithmes asymétriques
Le problème de la factorisation des entiers

- Exemple élémentaire: trouver les deux facteurs premiers des produits suivants
- 35 = 5x7
- 221=13x17
- 4453=61x73
- 503807=521x967
- 50123093=7297x6869

- Pour RSA-640 (193 chiffres décimaux ou 640 chiffres binaires)

Sécurité des algorithmes asymétriques
Le problème de la factorisation des entiers

- Pour RSA-640 (193 chiffres décimaux ou 640 chiffres binaires):
- Trouver les deux facteurs premiers de:
- N=3107418240490043721350750035888567930037346022842727545720161948823206440518081504556346829671723286782437916272838033415471073108501919548529007337724822783525742386454014691736602477652346609

- P=163473364580925384844313388386509085984178367003092312181110852389333100104508151212118167511579
  x
- q=190087128166482211312685157393541397547189678996851549366663853908802710380210449895719126146557 1

- Effort de 6 mois de calcul équivalent à 30 années de calcul d'une machine 2.2GHz-Opteron-CPU [F. Bahr *et al.*, 2006]

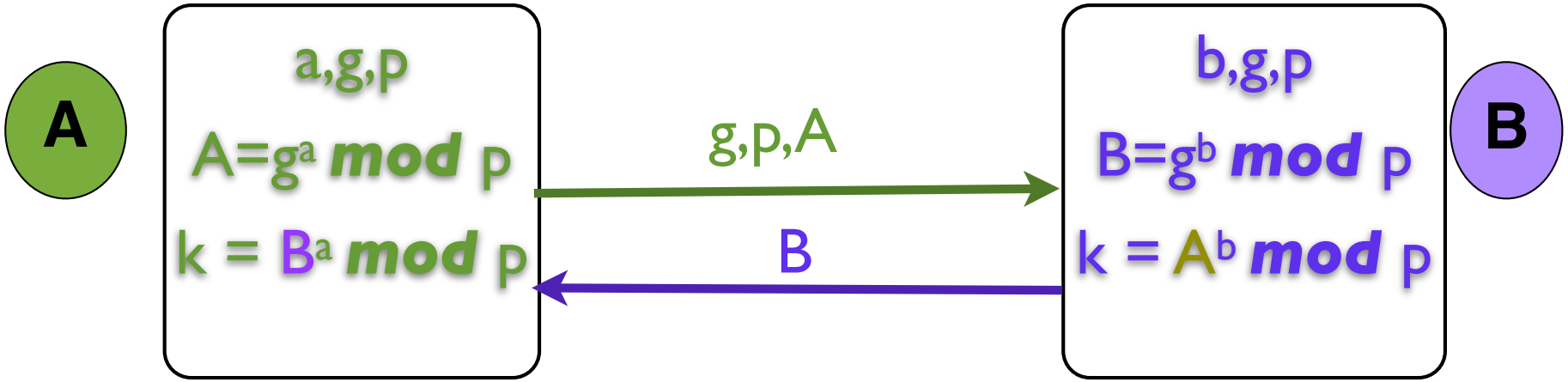
Sécurité des algorithmes asymétriques
Le problème du logarithme discret

- Etant donné deux nombre *g* et *x*.
  - Facile de faire $y = g^x$
- Etant donné y et g
  - Difficile de trouver *x* tel $y=g^x$

- C'est la difficulté présumée du logarithme discret
  - **Diffie-Hellman (1976)** ***et El-Gamal(1984)*** reposent sur ce système
    - Génération de clé (Diffie-Hellman)
    - Chiffrement/Déchiffrement (El-Gamal)
    - Signature/Vérification (DSA 1991 (NIST))

Echange de clés avec Diffie-Hellman

- En cryptographie, l'échange de clés Diffie-Hellman, du nom de ses auteurs Whitfield Diffie et Martin Hellman, est une méthode, publiée en 1976,



$K = A^b \bmod p = (g^a \bmod p)^b \bmod p = g^{ab} \bmod p$

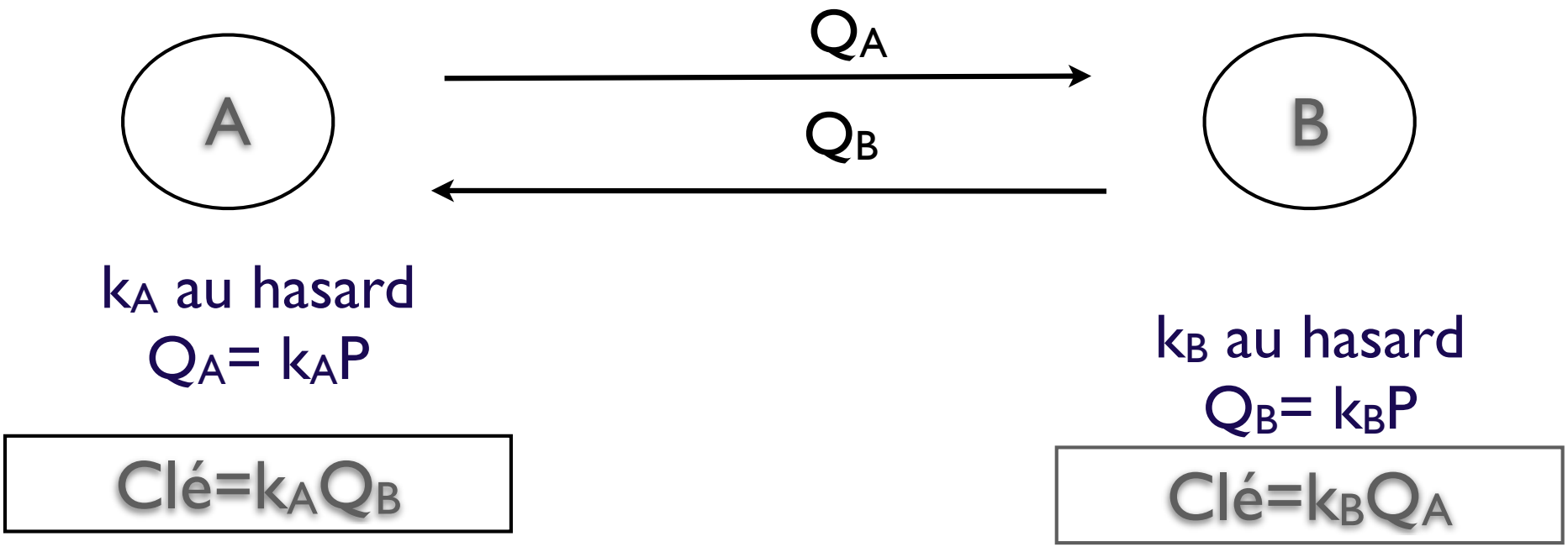
Sécurité des algorithmes asymétriques

Le problème du logarithme discret elliptique

- Etant donné un point *P* d'une courbe elliptique et un scalaire *d*.
  - Facile de calculer le point *Q= dP*
- Etant donné Q et P deux points de la courbe
  - Difficile de trouver le scalaire *d* tel *Q=dP.*

- C'est la difficulté présumée du logarithme discret elliptique
  - **Diffie-Hellman (1976) *et El-Gamal(1984)*** reposent sur ce système
    - Génération de clé (Diffie-Hellman)
    - Chiffrement/Déchiffrement (El-Gamal)
    - Signature/Vérification (ECDSA 1992 Scott Vanstone (NIST))

Sécurité des algorithmes asymétriques
Echange de clés avec Diffie-Hellman



Clé commune=$k_A k_B P$

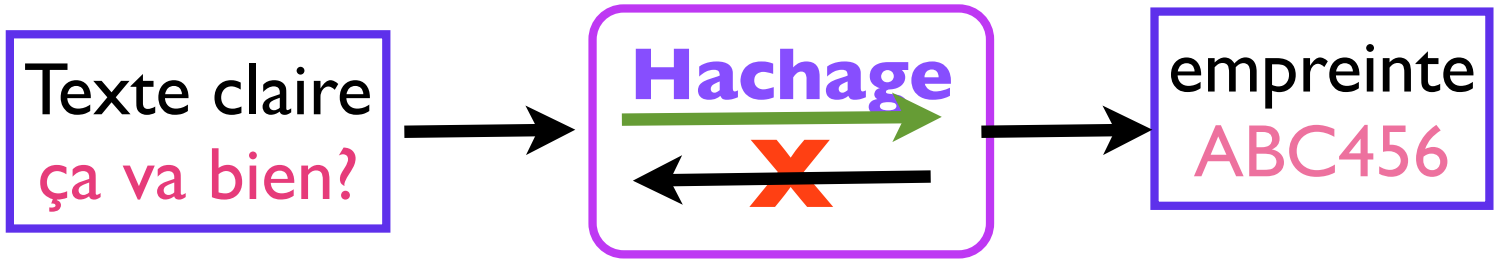
Les fonctions de hachage

Usage de fonction de Hachage

☛En cryptographie asymétrique, plus la taille des données est grande plus les opérations sont plus coûteuses

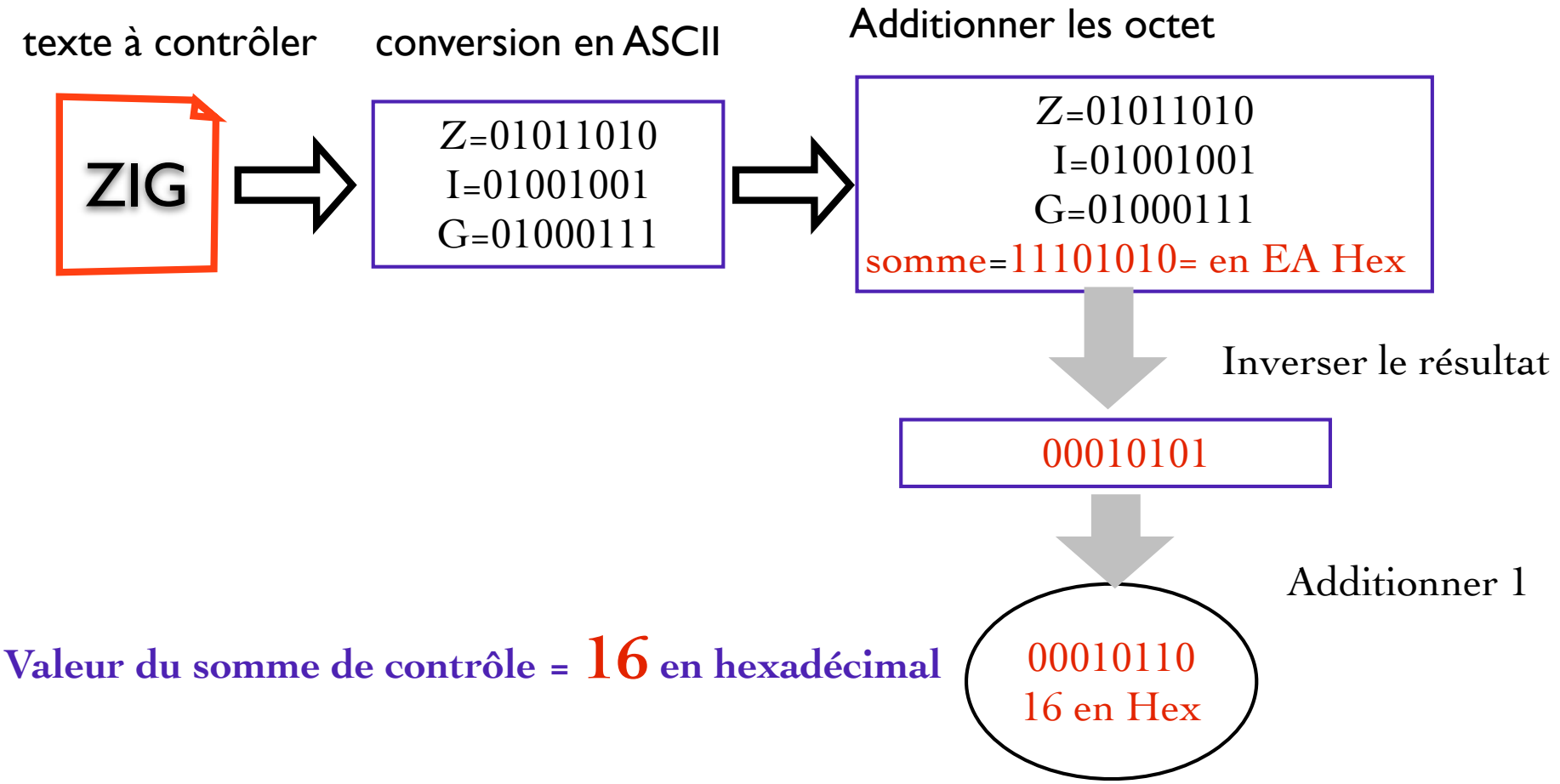
☛Les fonction de hachage permettent de réduire la taille des données par la création d'empreinte

✓Une fonction de hache est un algorithme difficilement irréversible, qui, appliquée à des données produit une unique empreinte (hach ou condensé etc.). A partir de l'empreinte, il est difficile de retrouver les données. X



Usage de fonction de Hachage

☛ Algorithme de hachage simple: somme de contrôle de 8 bits.



Usage de fonction de Hachage

- Hormis le caractère irreversible, une propriétés très importante des fonctions de hachage est: la résistance au collisions

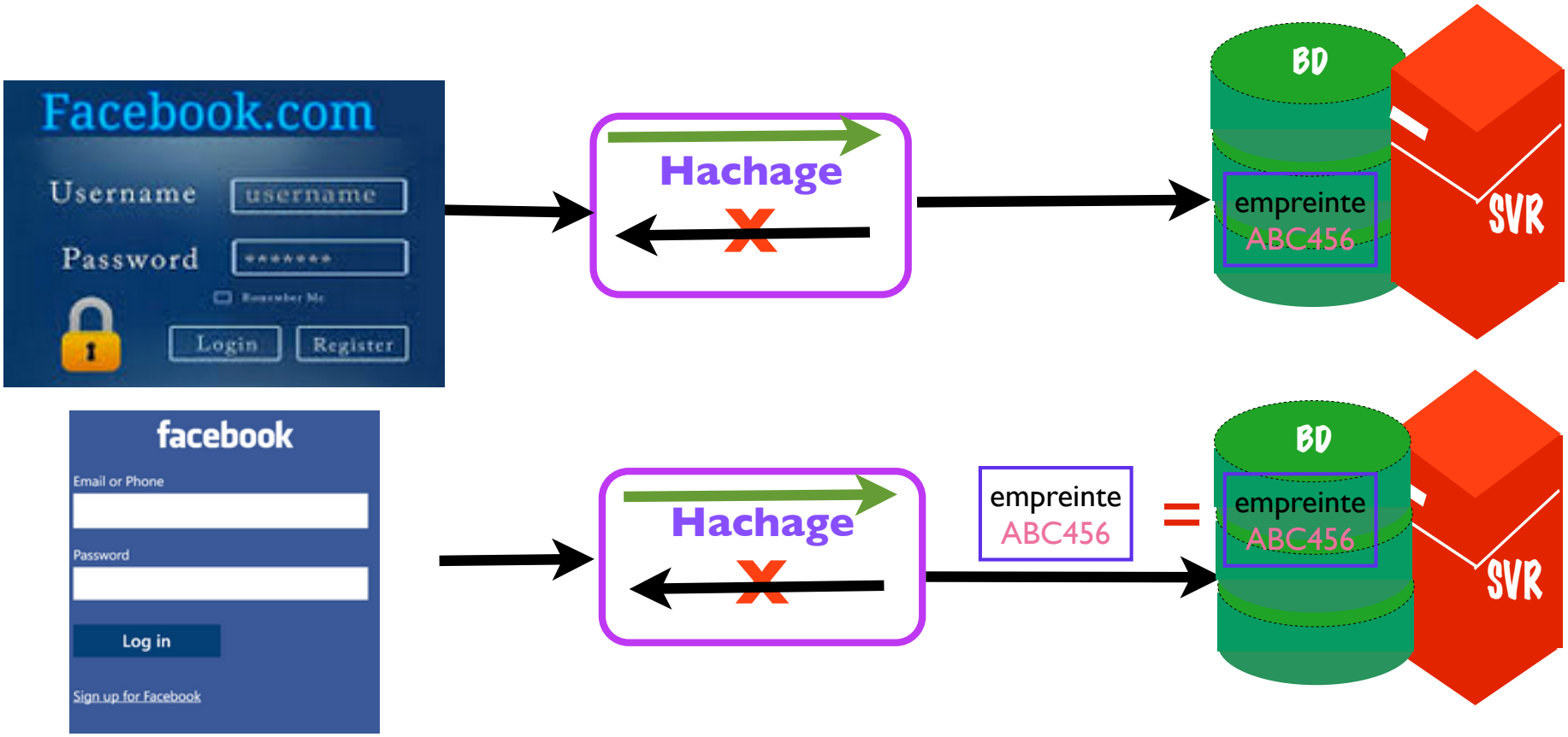
- Quelques algorithmes de hachage:
  - Construction de Merkle-Damgard
    - MD5 128 bits 1991 (empreinte de 128bits)
    - SHA1 160 bits 1995 (plus resistant au collision que MD5)
    - SHA2 256-512 bits 2001 (plus resistant au que SHA1)
  - Construction de Keccac
    - SHA2 256-512 bits 2001 (plus resistant au que SHA1)

Usage de fonction de Hachage

- Application des fonctions de Hachage H
  - ✓ Diminution de la taille des données
  - ✓ Pour la comparaison et non pour le chiffrement
- Propriétés de base
  - ✓ Sécurité: fonction non réversible
  - ✓ Taille fixe: les données longues et courtes produisent la même taille de données en sortie
    - ◉ Exemple: les données “ab” et “abcdefgh” engendre à la sortie de la fonction H la même taille 128 bits.
  - ✓ Des données différentes ne produise pas la même empreinte
    - ◉ Exemple: les données “ab” et “abcdefgh” n’engendre pas la même empreinte à la sortie de la fonction H

Application des fonctions de Hachage

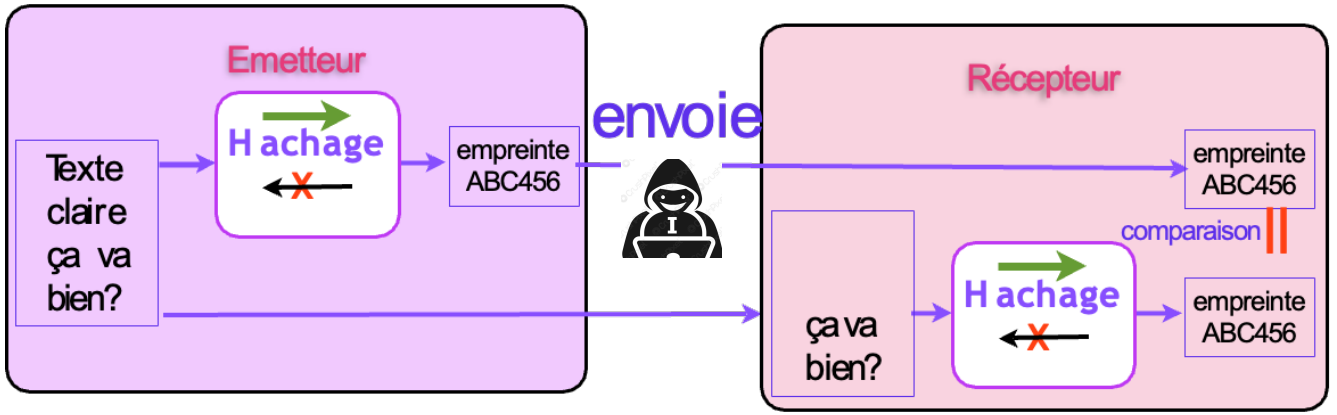
- Application: Principalement utilisé pour les mots de passe

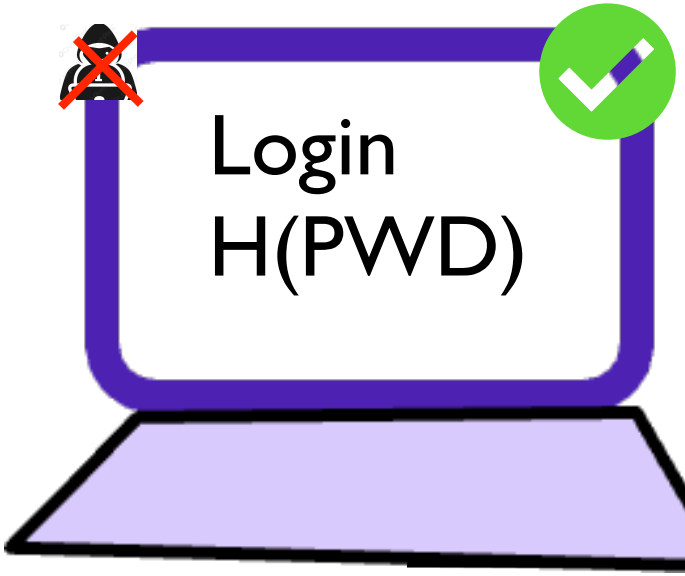


Les mots de passe doivent toujours être stockés cryptés.

Application des fonctions de Hachage

- Application: Envoie/Réception vs Login/Password sur PC





Les signatures numériques

Cryptographie asymétrique
signature numérique

☛La signature (SN) numérique est équivalente à la signature manuelle, c'est une vérification électronique de l'identité de l'émetteur:

☛Elle offre trois services de sécurité

✓Authentification: SN permet au récepteur de vérifier (d'authentifier le message) que le message est envoyé par le supposé émetteur.

✓Non répudiation: avec SN, l'émetteur ne peux pas nier avoir émis le message

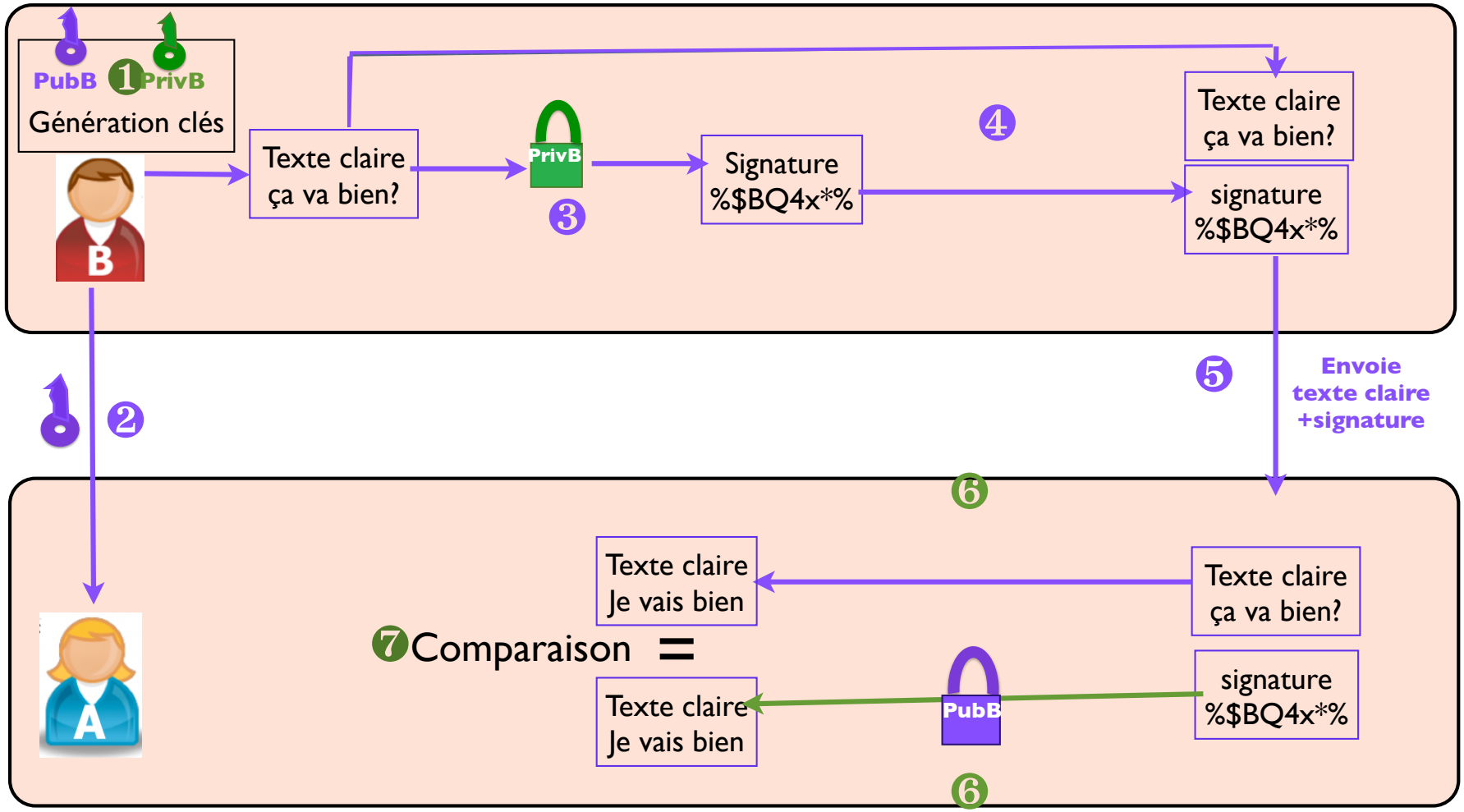
✓Intégrité: SN vous assure que le message n'a pas été modifié ou altéré durant sa transmission.

☛SN est très utilisée pour la distribution de logiciels et les transactions financières

☛SN est aussi populaire avec les transmission d'emails

Cryptographie asymétrique
signature numérique

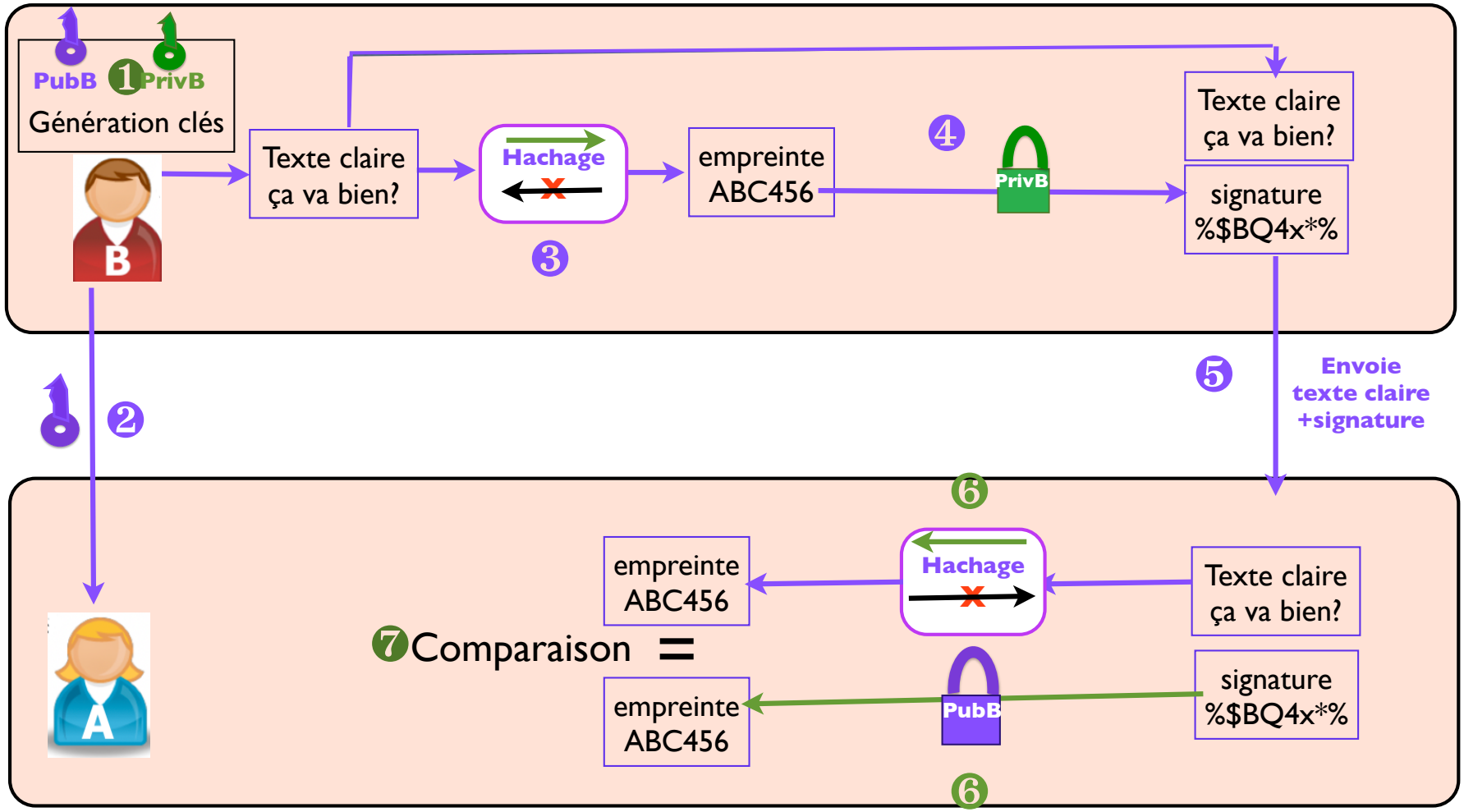
☛B veut envoyer un message signé a A



☛L'intérêt de la signature numérique n'est pas de crypter le message, car celui-ci est envoyé en claire.

Cryptographie asymétrique
signature numérique

☛B veut envoyer un message signé a A

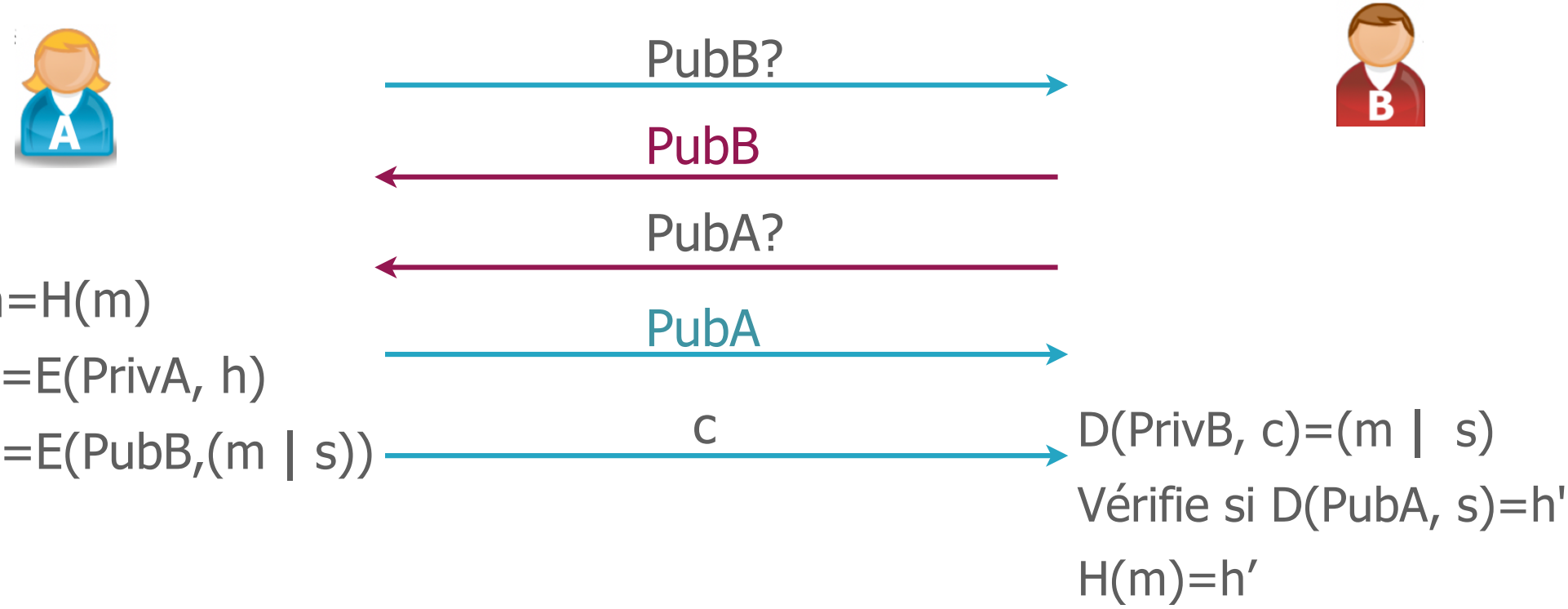


☛L'intérêt de la signature numérique n'est pas de crypter le message, car celui-ci est envoyé en claire.

Les protocoles cryptographiques

Protocoles cryptographiques

- Chiffrement hybride: Confidentialité, Authentification, Intégrité
- ☛A veut envoyer un message secret à B



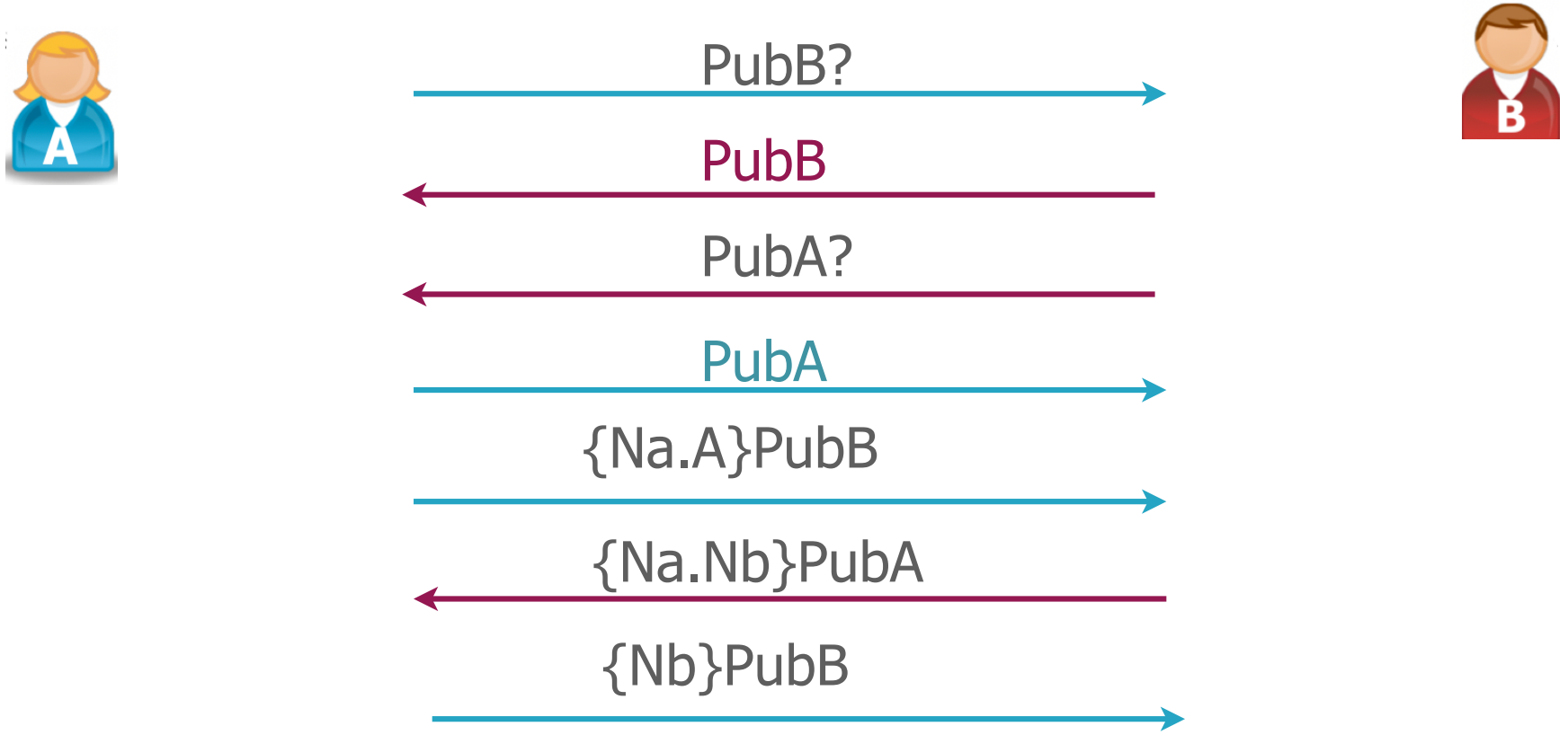
Chiffrer puis signer: c=E(PubB, m) et s=E(PrivA, h(c)), envoyer c | s)

Chiffrer et signer: c=E(PubB, m) et s=E(PrivA, h(m)), envoyer c | s)

Signer puis chiffrer:s=E(PrivA, h(m)) et c=E(PubB, m | s) et, envoyer c

Protocoles cryptographiques

- Authentification mutuelle: Needham-schroeder
- ☛A veut s'authentifier mutuellement avec B



Protocoles cryptographiques

- Chiffrement hybride: Authentification de clé partagé
- ☛A veut partager une clé symétrique avec B sans utiliser Diffie-Hellman





PubB?

PubB

PubA?

PubA

Na: nombre aléatoire

Ca=E(PubB, Na)

Ca

Nb: nombre aléatoire

Cb

Nb=D(PrivA, Cb)

Cb=E(PubA, Nb)

Na=D(PrivB, Ca)

Kab=Na⊕Nb

Kab=Na⊕Nb

h=H(m)

C

m | s=D(Kab,c)

s=E(PrivA, h)

h=D(PubA , s)

c=E(Kab,(m | s))

Vérifie si H(m)=h

Protocoles cryptographiques

- Chiffrement symétrique pour l'authenticité et l'intégrité: HMAC
- ☛A veut envoyer un message secret à B





PubB?

PubB

PubA?

PubA

Na: nombre aléatoire

Ca=E(PubB, Na)

Ca

Nb: nombre aléatoire

Nb=D(PrivA, Cb)

Cb

Cb=E(PubA, Nb)

Na=D(PrivB, Ca)

Kab=Na⊕Nb

h=H(Kab | H(Kab | m))

Kab=Na⊕Nb

c=E(Kab, (m | h))

C

m | h=D(Kab,C)

Vérifie si

h=H(Kab | H(Kab | m))

Protocoles cryptographiques

- Attaque **Man In the Middle** sur l'authenticité, la confidentialité et l'intégrité
- ☛A veut envoyer un message secret à B







PubB?

B,PubM

B,PubB

m=Hello B

c=E(PubM, m)

C

m=D(PrivM,c)

c=E(PubB,m)

C'

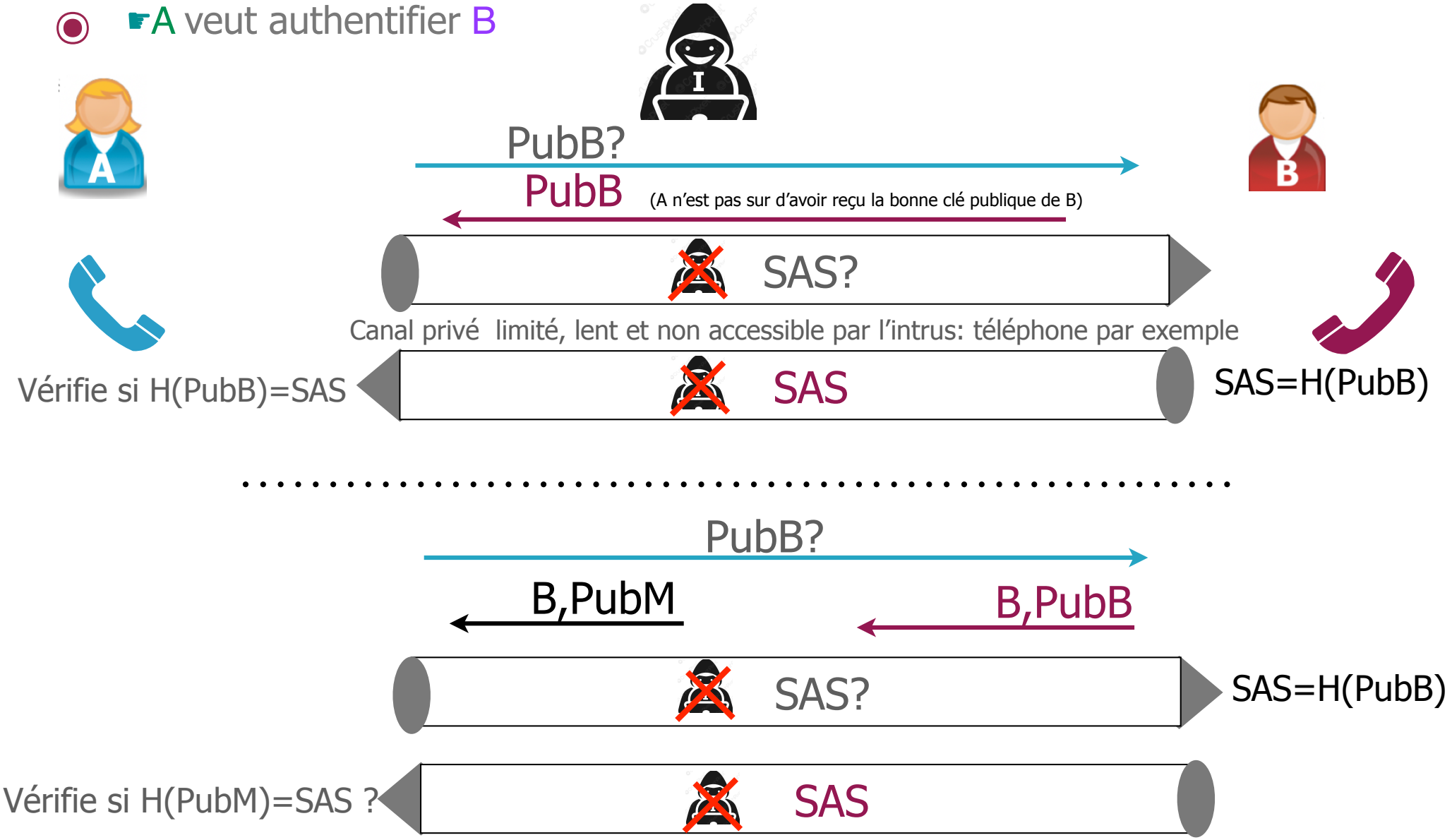
m=D(PrivB, C)

- Cette attaque n'est possible que si A et B sont à plus d'un saut l'un de l'autre
- Nécessité d'authentifier la clé publique
  - Short Authenticated Strings
  - Certificat numérique
  - Web of Trust

Authenticité de la clé publique

Authentification de clé publique

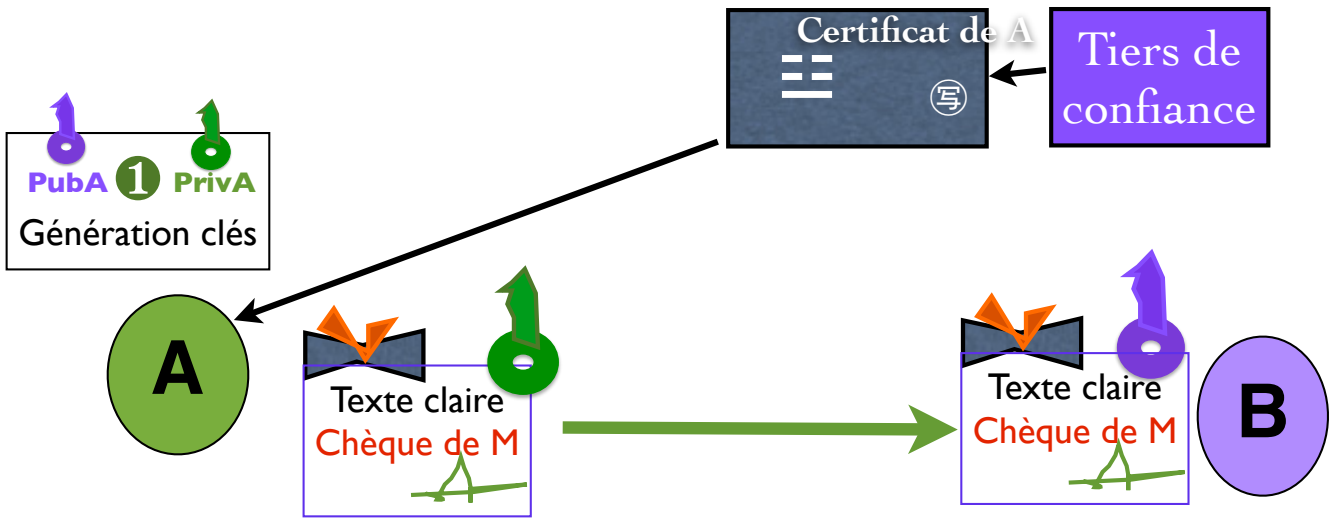
- **SAS**: utilise des chaines de caractères courtes via un canal secret pour vérifier si les clés publiques échangées sur le canal principal n'ont pas été modifiée
  - A veut authentifier B



Cryptographie asymétrique
certificat numérique

☛Le certificat électronique est composé d'identités issues d'une tierce partie, à qui on a confiance. Il vérifie les entités et leur clé publique associée.

✓Quand A doit envoyer sa clé publique PubA à B, il ne demande pas à B de récupérer la clé PubA sur un site central, mais attache son certificat et PubA sur son message et envoie le tout (message signé+certificat+PubA) à B



☛Informations contenues dans le certificat

✓Nom du propriétaire du certificat

✓La clé publique du propriétaire et sa date d'expiration

✓Nom du producteur du certificat

✓La signature numérique du producteur du certificat

✓.....

Cryptographie asymétrique
certificat numérique

☛Le certificat numérique est basé sur la confiance ou une chaine de confiance.

✓Le tiers de confiance est une autorité de certification, une entité qui produit des certificats

- ✓Exemple: un passeport vérifie l'identité d'une personne si on a une confiance à l'organisme l'ayant délivré.
- ✓Nous faisons souvent appel à un notaire (tier de confiance) lors de la signature d'un contrat important

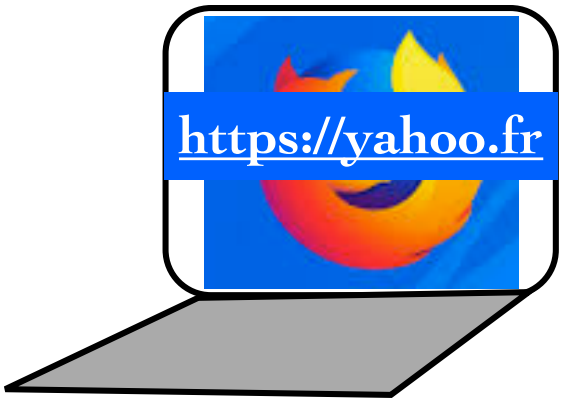
✓Le certificat numérique vérifie l'identité de la clé publique du propriétaire i.e si l'entité prétendant signer le message est celle qu'elle prétend être.

Cryptographie asymétrique
certificat numérique (SSL)

☛Les certificat SSL permettent d'établir la confiance navigateur-serveur-Web dans https.

✓Un certificat SSL, est un certificat numérique d'un serveur web délivré par une tierce parti de confiance (la CA) qui le signe

✓Il vérifie l'identité du serveur et sa clé publique



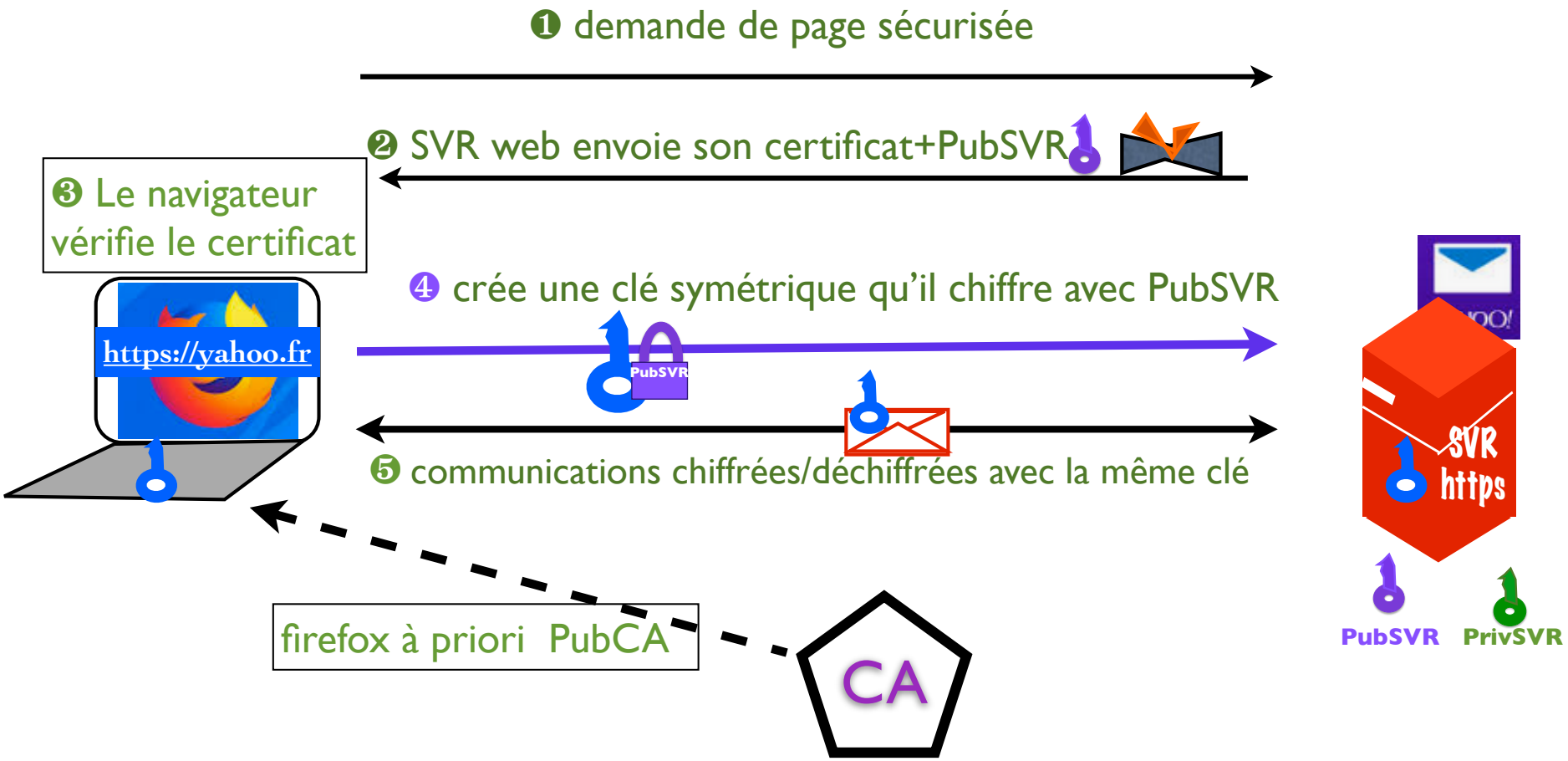




- L'autorité de certification (CA) signe le certificat avec sa clé privée
- Le navigateur est à priori installé avec des clés publiques de CA, il peux vérifier les certificat

Cryptographie asymétrique certificat numérique (SSL)

☛https://yahoo.fr sur la barre d'adresse du navigateur, indique une demande de page sécurisée au serveur web



Cryptographie asymétrique certificat numérique (SSL)



☛Le cadenas gris indique que la clé publique du serveur est à lui

☛Les communications entre le browser et le serveur web sont chiffrées par une clé symétrique: SSL associe les deux formes cryptographique

☛se connecter à un site avec https, indique que les communications sont chiffrées et non que le site est sûr, car aussi bien une personne bien intentionnée, un hacker peut obtenir un certificat SSL pour son site.

☛Connecter vous à des sites avec une bonne réputation

Cryptographie asymétrique
certificat numérique (SSL) auto-signé

☛2 méthodes pour la sécurité **serveur web-client web**

- •1. Payer un certificat SSL auprès d'une CA (comme Symantec, DigiCert etc.)
- •2 Créer librement son propre certificat SSL: **certificat auto-signé**
  - •Le certificat auto-signé**, est signé par la même entité**
  - •Il peut être créer en utilisant OpenSSL, java's keytools, Adobe Reader etc.

☛Certificat SSL auto-signé

•Crois moi, je suis celui que je prétend être

•Il n'est pas connu des browser



☛Certificat SSL commercialisé

•Crois moi, Symantec dit que je suis celui que je prétend être

•Il est connu des navigateurs



Cryptographie asymétrique
certificat numérique (SSL) auto-signé

☛Les certificats auto-signés ont le même niveau de sécurité que les certificats commercialisés, seulement ils sont moins réputés.

☛ Si un certificat auto-signé est distribué et installé sur les navigateurs qui accèdent à votre site, il est autant sécurisé qu'un certificat commercialisé.

☛ Le certificat auto-signé est limité: il marche bien pour un petit groupe de personnes qui utilisent votre site.

Sécurité des mots de passe

Sécurité des mots de passe

résistance aux attaques par force brute



Quelques mesures à prendre en compte faces aux attaques sur les mots de passe

- La robustesse (mot de passe fort, mot de passe faible)
- **Mot de passe unique pour chaque compte**
- Le changement périodique du mot de passe
- Etc....

Sécurité des mots de passe

résistance aux attaques par force brute

Robustesse des mot de passe

- Les mots de passe sont plus ou moins résistants aux attaques selon leur composition. Leur résistance aux attaques par force brute dépend:
- La longueur
  - plus il est long, plus il est résistant
  - Avec 26^6 = 308 915 776 combinaisons d'attaques par force brute on trouve un mot de passe composé de 6 lettres alphabétiques, alors qu'avec 4 lettres, il en faut juste 26^4=456975 combinaisons
- Une composition mixte (lettres, chiffres,caractères spéciaux, minuscules, majuscules etc..
  - Comparé à un mot de passe de 6 lettres alphabétiques, un mot de passe de 6 lettres alphanumériques nécessite 36^6=2 176 782 336 combinaisons d'attaques par force brute pour être connu